



POL-VRM-01: Third-Party & Vendor Risk Management Policy

Enterprise Governance Framework for External Supplier Relationships

Document ID:	POL-VRM-01
Author:	IT Compliance & Security Team
Standards Framework:	ISO/IEC 27001:2022 SOC 2 Type II (Trust Services Criteria)
Classification:	Internal Confidential Policy Document
Last Reviewed:	July 2026

Third-Party & Vendor Risk Management Policy

Compliance Matrix Mapping:

ISO/IEC 27001:2022: Control A.5.19 (Information security in supplier relationships), A.5.20 (Addressing information security within supplier agreements), A.5.23 (Information security for use of cloud services).

SOC 2 Type II: Common Criteria 9.2 (Assesses and manages risks associated with vendors and business partners).

1. Purpose

This policy defines the mandatory framework for identifying, assessing, mitigating, and monitoring information security risks associated with third-party vendors, suppliers, and SaaS providers. The objective is to ensure that external entities maintaining, processing, or accessing organizational assets adhere to security standards equivalent to our own.

2. Scope

This policy applies to all third-party relationships, including cloud service providers (IaaS, PaaS, SaaS), independent contractors, external consultants, and open-source software dependencies that interact with production environments or corporate data.

3. Core Policy Requirements

3.1 Vendor Classification & Tiering Framework

Before procurement or engineering integrates any third-party service, the service must be classified into a risk tier based on the data classification and environment access it requires:

- **Tier 1 (High Risk):**

- **Definition:** Vendors with broad access to production environments, networks, or systems storing Personally Identifiable Information (PII), intellectual property, or financial records.
- **Examples:** Cloud infrastructure providers (AWS/GCP), Core CI/CD tools, Identity Providers (IdPs), and primary customer data platforms.

- **Tier 2 (Medium Risk):**

- **Definition:** Vendors with access limited to internal corporate systems and corporate productivity applications, with zero production data or environment access.

- **Examples:** Internal project management platforms, corporate communication tools, and HR administrative software.
- **Tier 3 (Low Risk):**
 - **Definition:** Vendors with no system or network connectivity, and zero access to internal company systems or corporate data.
 - **Examples:** Facilities management, office supply providers, and external creative agencies handling publicly available materials.

3.2 Pre-Onboarding Due Diligence & Assessment

No Tier 1 or Tier 2 vendor may be signed, integrated, or permitted to ingest company data without passing a formal Information Security Assessment conducted by the Compliance and Security Team.

- **Required Audit Trails for Tier 1:** Vendors must provide a current **SOC 2 Type II report** (covering a minimum 6-month review period with clean auditor opinions) and/or a valid **ISO/IEC 27001 certification**.
- **Alternative Questionnaires:** Vendors lacking standardized audit reports must complete a standardized security questionnaire (e.g., CAIQ or SIG) evaluating their encryption (at rest and in transit), access controls, vulnerability workflows, and business continuity readiness.
- **Exemption Process:** Any exceptions to these security requirements must be documented, tied to a compensating control, and formally signed off by the CISO or Head of Information Security.

3.3 Mandatory Contractual Safeguards

All third-party Master Service Agreements (MSAs) and Data Processing Addendums (DPAs) must include specific, binding security clauses:

- **Right to Audit:** The explicit right for our organization (or a designated independent third party) to audit the vendor's security posture annually.
- **Breach Notification SLA:** A mandatory requirement for the vendor to notify our Security Operations Team of any suspected or confirmed security incident within 24 hours of discovery.
- **Data Return and Destruction:** Clear requirements detailing how company data will be securely deleted or returned upon contract termination, adhering to sanitized data destruction standards.

3.4 Continuous Monitoring & Annual Re-Assessments

Vendor risk is monitored dynamically rather than managed as a point-in-time check.

- **Mandatory Annual Reviews:** All Tier 1 vendors must undergo a formal security re-assessment every twelve (12) months. This process requires collecting their newly issued annual SOC 2 Type II reports and validating that the vendor's Complementary User Entity Controls (CUECs) are actively implemented within our own internal controls.

- **Continuous Monitoring:** The Security Team may deploy automated continuous monitoring tools (such as security rating services) to track real-time patch compliance and public domain vulnerabilities of Tier 1 and Tier 2 vendors.

3.5 Out-of-Cycle Re-Assessments

A formal security review will be triggered immediately outside the standard annual window if either of the following events occurs:

1. **Vendor Security Incident:** The vendor suffers a confirmed or highly suspected data breach, credential leak, or critical infrastructure availability failure.
2. **Material Change in Scope:** The vendor's deployment changes significantly (e.g., a Tier 2 project management tool is upgraded to pull live customer telemetry from a Tier 1 production environment).

3.6 Vendor Offboarding & De-provisioning

Upon termination of a third-party contract, a formal offboarding checklist must be executed immediately:

- **Access Revocation:** All logical access, including Enterprise Single Sign-On (SSO), API keys, service accounts, and physical access badges, must be revoked within 24 hours of contract termination.
- **Data Purge Verification:** The vendor must provide a formal Certificate of Destruction or written sign-off confirming that all company data has been permanently purged from their primary systems, backups, and logs.